加雲聯網股份有限公司

Security Management Plan

版 別：1.0

制訂日期：2024 年 5 月 XX 日

修訂日期：2024 年 5 月 XX 日

制修部門：XXX

頁 數：X

核准	審查	制定

文件發行/修訂記錄

版次	發行日期	生效日期	制修內容摘要
1.0			

Content

1.0 Purpose 4
1.1 Introduction 4
1.2 Purposes and Objectives 4
2.0 Scope of application 4
3.0 Definitions 5
3.1 Definitions 5
3.2 Abbreviations 5
3.3 Applicable Documents 6
3.3.1 Employer’s Requirements 6
3.3.2 Related Documents 6
4.0 Project Assets and Suc Description 7
5.0 Cybersecurity Documentation 8
6.0 Documentation Of Policies and Procedures for Protecting the Assets 9
7.0 Cybersecurity Governance 9
8.0 Project Role & Responsibility 10
9.0 Timeline of Implementation and Personnel Dedication 12
10.0 Organization Controls Planning for Gates 14
11.0 Testing Cases and Programs for Systems 15
12.0 Permit to Work (PtW) processes 15

1.0 Purpose

1.1 Introduction

This document describes the required work scope and management of the OT Security requirements of this project. This document also describes the document delivery planning for assets and SuC, cybersecurity documentation, policies and Procedures, Cybersecurity Governance, Timeline, and Testing.

1.2 Purposes and Objectives

The policies and procedures aim to ensure a systematic and secure approach to applying updates, maintaining system integrity, and minimizing vulnerabilities within the OT environment.

2.0 Scope of application

The System under Consideration (SuC) for IEC 62443-2-4 Dummy System, the applicable scope of systems, sub-components for OT Security Management Plan are shown in the following table, which based on the “OT Security Detailed Risk Assessment Report”. The asset list could refer to “Dummy Project - Inventory Asset List”.

The applicable scope of systems, sub-components for this management plan includes:

Location	Asset	Description
03 SCADA Zone	SCADA HMI Server	Graphical monitoring interface
02 Control Zone	IED (Control)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks
01 SIS Zone	IED (Protection)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks
02 Control Zone	Ethernet Switch (Control)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device
01 SIS Zone	Ethernet Switch (Protection)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device
05 Tempory Zone	Wireless AP	A networking hardware device that allows other Wi-Fi devices to connect to a wired network or wireless network

3.0 Definitions

3.1 Definitions

Definition	Description
Asset Owner	Individual or organization responsible for one or more Industrial Automation and Control Systems (IACSs).
Automation Solution	Control system and any complementary hardware and software components that have been installed and configured to operate in an IACS.
Component	One of the parts that make up a product or system.
Dependent Component	Component external to the product on which the product depends.
Integration Service Provider	The service provider that provides integration activities for an Automation Solution including design, installation, configuration, testing, commissioning, and handover.
Maintenance Service Provider	The service provider that provides support activities for an Automation Solution after handover.
Product Supplier	Manufacturer of hardware and/or software products.
Recovery Point Objective	Time value that determines the maximum tolerable period of data loss due to a disaster (e.g., data corruption).
Recovery Time Objective	The overall length of time an information system's components or an operating system's components can be in the recovery phase before negatively impacting the organization's mission or mission/business/operating functions.
Service Provider	Individual or organization (internal or external organization, manufacturer, etc.) that provides a specific support service and associated supplies in accordance with an agreement with the asset owner.

3.2 Abbreviations

Abbreviation	Clarification
EPC	Engineering, Procurement and Construction
SAT	Site Acceptance Test
SIT	Site Integration Test
VIT	Vulnerability Identification Testing

3.3 Applicable Documents

3.3.1 Employer's Requirements

No	Employer's DOC No	DOC Title
1		OT Security Requirements for dummy project
2		Master Time Schedule

3.3.2 Related Documents

No	ICP DOC No	Employer's DOC No (if applicabe)	DOC Title
1			OT Security Management Plan
2			OT Security Vendor Management Plan
3			Dummy Project -Data Flow Diagram
4			Dummy Project - Inventory Asset List
5			Dummy - Simple Network Diagram
			Dummy Project -Initial Risk Assessment
			Dummy Project -Detail Risk Assessment

4.0 Project Assets and Suc Description

The System under Consideration (SuC) for IEC 62443-2-4 Dummy System, the applicable scope of systems, sub-components for OT Security Management Plan are shown in the following table, which based on the “OT Security Detailed Risk Assessment Report”. The asset list could refer to “Dummy Project - Inventory Asset List”.

The applicable scope of systems, sub-components for this management plan includes:

Location	Asset	Description	Services running
03 SCADA Zone	SCADA HMI Server	Graphical monitoring interface	1.iControl：Main software of IED HMI, used for graphic monitoring in substation. 2.Splunk agent 3.Palo Alto 4.Aconex agent
02 Control Zone	IED (Control)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks	N/A
01 SIS Zone	IED (Protection)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks	N/A
02 Control Zone	Ethernet Switch (Control)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device	N/A
01 SIS Zone	Ethernet Switch (Protection)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device	N/A
05 Tempory Zone	Wireless AP	A networking hardware device that allows other Wi-Fi devices to connect to a wired network or wireless network	N/A

5.0 Cybersecurity Documentation

The following document will be submitted during the project execution, referring to OT Security Requirements for dummy project.

<u>Design phase and Gate 1:</u>

- Security Management Plan:
- Project (lifecycle) Security Management Plan
- Security Vendor Management Plan
- (Security) Policies and Procedures Management Plan, including
- Account Management policy
- Vulnerability Management procedure
- Backup/Restore procedure
- Systems Malware Protection procedure
- Change and Patch Management procedure
- Logging, monitoring, and reporting procedure
- Inventory Asset List
- Simple Network Diagram
- Initial (Preliminary) Threat and Risk Assessment Report

<u>Detail Design phase and Gate 2:</u>

- Asset Inventory List
- Security Architecture: Network and Data Flow Diagram
- Detail Risk Assessment Report
- Security Risk Mitigation Plan, including security controls

<u>Implementation and Verification and Validation phase, and Gate 3</u>

- IACS Automation Solutions/Asset Hardening Recommended Practices
- Security Functional Description Specification (O&M manual)
- Inspection and Test Protocol for FAT, SAT, and SIT
- Security Solution Integration Plan
- Incident response and recovery plan
- FAT, SAT, and SIT Test Report

6.0 Documentation Of Policies and Procedures for Protecting the Assets

The documentation of policies and procedures for protecting the assets include:

- Vendor Management policy
- Account Management policy
- Vulnerability Management procedure
- Backup/Restore procedure
- Systems Malware Protection procedure
- Change and Patch Management procedure
- Logging, monitoring, and reporting procedure

7.0 Cybersecurity Governance

ICP would be responsible for compliance with cybersecurity requirements for implementing, managing, and monitoring compliance with OT Security Requirements for dummy projects.

ICP would supervise the activities of its suppliers to ensure their compliance as described in the vendor's management plan, to manage the contractor selection, system implementation, various testing, and documents delivery, etc. to meet the various security requirements for the Employer.

Request and training the team members and subcontractors/consultants to follow the requirement from the Employer:

- The Employer’s security requirements, policies, and procedures
- The Employer’s Management of Change (MOC) and Permit to Work (PtW) processes for changes involving devices, workstations, and servers and connections between them. Chapter 13.0 Appendix A. personnel change notification Form could be used to perform the notification to the Employer.
- The protection of the confidentiality of the Employer’s data. All the policies, procedures required to protect the confidentiality of the asset owner's data also shall be listed. These requirements shall be implied into the Delegation Contract of subcontractor and/or consultant. The protection of the confidentiality is divided to 4 different categories that data is placed into—depending on its risk and value, include:
  - Public data

    Public data is freely available and does not require any special security measures.

  - Project Internal data

    Internal data is only intended for use within this project, and can include things like the employee handbook, project policies, and certain company-wide communications. Though it should remain private, if this type of information were to be made public, the repercussions would be minimal.

  - Confidential data

    Confidential data must be kept within the project/organization and should only be accessed by authorized personnel. It can include information like pricing details, project system materials,

meeting minutes or contact information. If this type of data were to be disclosed, it could damage the project/company or brand.

- Restricted data

  Restricted data requires the highest level of protection and access must be limited to necessary personnel. Often protected by a Non-Disclosure Agreement (NDA), restricted data can include system design and develop related documents, Various plans and V&V documents, and personally identifiable information (PII), etc.

- Direct personnel to comply with protection of the confidentiality of PE/O's data.

ICP shall handle project regular meetings with Employer, report and discuss following but not limited to:

- Project Interfaces to report the changes of new personnel who need to get access to the solution, and get the approval
- Project Interfaces to inform the changes to personnel who no longer need access to the solution, and get the approval
- Review project progress
- Manage the quality of documents
- Submit deliverable documents after the document stage review
- Develop Policies and Procedures Integration Plan
- Assist the Employer in performing the test according to the Inspection and Test Protocol
- Documentation and report of SIT

8.0 Project Role & Responsibility

Organizations & Project Teams	**Role**	**Responsibility**
Asset Owner Team	Asset Owner for Dummy	• Set the project requirements (including cybersecurity requirements) • Provide final approval on cybersecurity assessments, reviews, and decisions in accordance with requirements documented in OT Security Requirements for dummy project • Accept the project deliverables.
ICP Project Manager Team	EPC	• Project Management • Handle project regular meetings • Submit deliverable documents • Develop Policies and Procedures Integration Plan • Assisting the Employer to perform the SIT test • Verify and report the Gate 3 Review - Compilation of all OT-security related documents
OT-security Consultant Team	Consultant and Verification for Dummy Project	• OT security consultant and documentation guidance for ICP and Vendors • Develop Police and Procedures

		• Develop OT Security Management Plan • Develop Vender Management Plan • Develop Awareness Material • Perform Initial Level Risk Assessment with employer and system integrators • Verify and report the Gate 1: IEC 62443-2-4 organizational controls self-assessment • Perform Detailed Risk Assessment with employer and system integrators • Report the Risk Mitigation Plan • Develop OT-Security Inspection and Test Protocol plan document for OT-security only • Update requirements and security solutions for OT-Security Policy and Procedure Design Practices • Support the developing of Integration Plan for OT-Security Policy and Procedure Design Practices • Verify and report the Gate 2: IEC 62443-2-4 organizational controls self-assessment • Planning and Reviewing the FAT Inspection and Test Protocol (ITP) procedures (OT-security only) • Verification and Review the Performing of the FAT test • Aggregation and Reporting - Documentation the FAT test • Planning and Reviewing the SAT Inspection and Test Protocol (ITP) procedures (OT-security only) • Verification and Review the Performing of the SAT test • Aggregation and Reporting - Documentation the SAT test • Planning and Reviewing the SIT Inspection and Test Protocol (ITP) procedures (OT-security only) • Consultant for the Employer to perform the SIT test • Consultant for the Gate 3 Review - Compilation of all OT-security related documents • Perform Training
Subcontractor/SI	System Integrator for Dummy Project	• Develop Preliminary Asset List • Develop Simple Network Diagram • Join and support the Initial Level Risk Assessment • Support Gate 1: IEC 62443-2-4 organizational controls self-assessment • Develop Asset List • Develop OT-Security Control System and Network Architecture • Perform Hardening Concepts and Practices • Implement security control & countermeasures to system and assets, include security solution (Like Setting username & password, install Antivirus), security procedure documents (e.g. account management, Vulnerability Management, backup/restore…), function requirements (IEC 62443-3-3, etc.) • Join and support the Detailed Risk Assessment • Support Risk Mitigation Plan • Support the development of the Inspection and Test Protocol (OT-security only) • Support OT-Security Policy and Procedure Design Practices • Support Gate 2: IEC 62443-2-4 organizational controls self-assessment

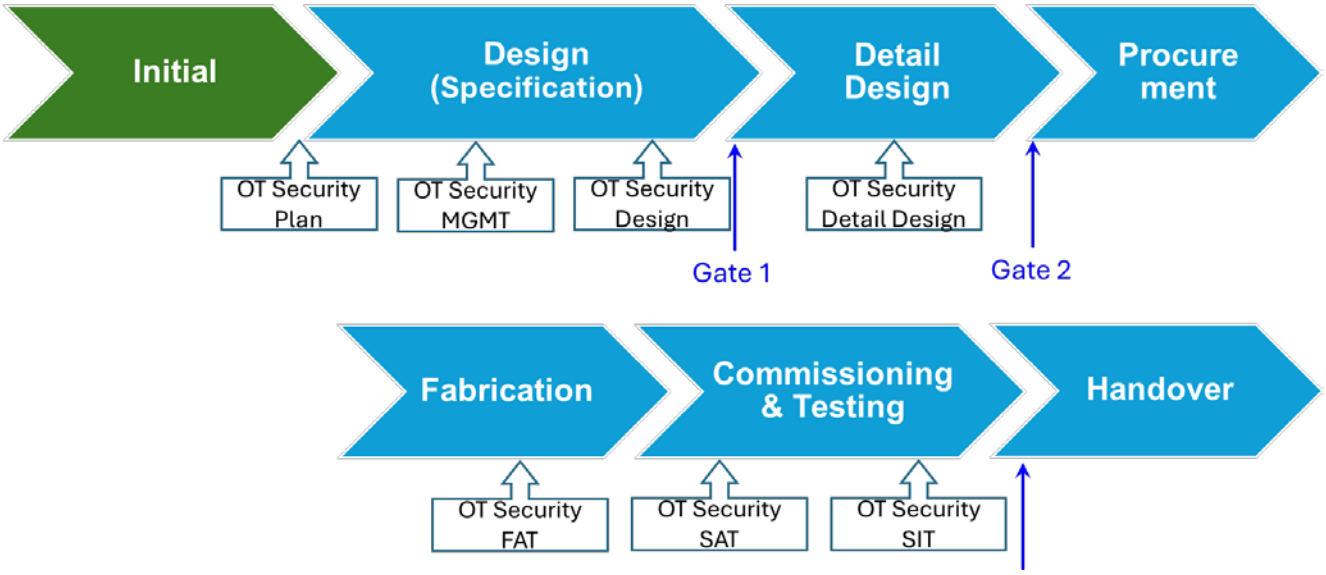
		• Develop the FAT Inspection and Test Protocol (ITP) test cases (OT-security only), and perform the tests and test reports (Some OT-Security tests could be performed by OT-security Consultant, if available) • Support the OT-Security FAT test report • Develop the SAT Inspection and Test Protocol (ITP) test cases (OT-security only), and perform the tests and test reports (Some OT-Security tests could be performed by OT-security Consultant, if available) • Join and support the SAT test as documented in the Inspection and test protocol • Support the OT-Security SAT test report • Support the Employer to perform the SIT test package
Suppliers	Product Supplier for Dummy Project	• Support for tasks of OT Security Design • Support for tasks of FAT TEST • Support for tasks of SAT TEST • Support for tasks of SIT TEST

9.0 Timeline of Implementation and Personnel Dedication

Activities	**Implementation**	**Duration (Working Days)**	**Predict Deadline**
OT Security Management	Policy and Procedures	15	
OT Security Management	OT Security Management Plan	5	
OT Security Management	Vendor Management Plan	5	
OT Security Management	Awareness Material	10	
OT Security Design	Preliminary Asset List	10	
OT Security Design	Simple Network Diagram	5	
OT Security Design	Initial Level Risk Assessment	10	
OT Security Detail Design	Detailed Risk Assessment	20	
OT Security Detail Design	Asset List	20	

OT Security Detail Design	Risk Mitigation Plan	15	
OT Security Detail Design	OT Security Architecture	20	
OT Security Detail Design	Hardening Concepts	15	
OT Security Detail Design	Inspection and Test Protocol	25	
OT Security Detail Design	Policies and Procedures Integration Plan	30	
FAT	Execution of FAT test as documented in the Inspection and test protocol	40	
FAT	Documentation and report of FAT	15	
SAT	Execution of SAT test as documented in the Inspection and test protocol	40	
SAT	Documentation and report of SAT	15	
SIT	Assist Employer performing the test according to the Inspection and Test Protocol	40	
SIT	Documentation and report of SIT	10	

10.0Organization Controls Planning for Gates



The Security Gates planed within this project are following:

- Gate 1 from Design to Detail Design phase – approval on OT Security Design
- Gate 2 from Detail Design to Procurement phase – approval on OT Security Detail Design
- Gate 3 from Commissioning and Testing to Hand Over phase – approval on OT Security FAT/SAT tests

Gate review process:

- Prior attending to the gate review meeting, all in attendance will review all pertinent documentation and have a good understanding of the project and its performance related to OT Cybersecurity.
- Contractor will make the arrangements for the meeting and communicate with other participants. The meeting will be arranged in Employer facilities. Before the gate review meeting is concluded the participants should ensure that the meeting has achieved its purpose and agreed upon next steps.
- The contractor will prepare a summary report including key findings upon completion of the gate review meeting. The report will be shared and approved by the Employer to ensure mutual understanding of the results of the gate review meeting.

11.0Testing Cases and Programs for Systems

This section provides the overview of how the testing will be performed and to gauge the effectiveness of the controls in place, for all the assets under System Under Consideration.

Asset	Description	Testing Details	Testing Timeline
SCADA HMI Server	Graphical monitoring interface	IEC 62443-3-3 and IEC 62443-4-2 requirements and Hardening Inspection	FAT/SAT/SIT
IED (Control)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks	IEC 62443-3-3 and IEC 62443-4-2 requirements and Hardening Inspection	FAT/SAT/SIT
IED (Protection)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks	IEC 62443-3-3 and IEC 62443-4-2 requirements and Hardening Inspection	FAT/SAT/SIT
Ethernet Switch (Control)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device	IEC 62443-3-3 and IEC 62443-4-2 requirements and Hardening Inspection	FAT/SAT/SIT
Ethernet Switch (Protection)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device	IEC 62443-3-3 and IEC 62443-4-2 requirements and Hardening Inspection	FAT/SAT/SIT
Wireless AP	A networking hardware device that allows other Wi-Fi devices to connect to a wired network or wireless network	IEC 62443-3-3 and IEC 62443-4-2 requirements and Hardening Inspection	FAT/SAT/SIT
Culvert Box (CUL System)	LV Supply and Distribution System (CMR)	IEC 62443-3-3 and IEC 62443-4-2 requirements and Hardening Inspection	FAT/SAT/SIT

12.0Permit to Work (PtW) processes

All project team members (included subcontractors and consultants) work on site shall follow the permit to work (PtW) policy and processes requested by Asset Owner.

13.0Appendix

A. personnel change notification Form

_____ Project personnel change Notice

Date:_____

Company/Employee Name:_____ SSN:_____

Employment or Change Information

☐ **Employment** ☐ **Change**

☐ Full Time ☐ Rate/Salary:_____

☐ Part Time:_____ ☐ Employee Data:_____

☐ Temporary:_____ ☐ Other (specify):_____

Start Date:_____ ☐ Effective Date:_____

Category	Previous	New/Starting
Title:		
Department:		
Rate (Hourly/Salary):		
% Increase:		

Termination Information

☐ Voluntary Final Day of Work:_____

☐ Involuntary Accrued Paid Time Off:_____

Severance Pay Approved:_____

Reason for Termination (attach any supporting documentation):_____

_____

_____

Approvals

ICP/Project Manager :_____ Date:_____

Employer/ Manager :_____ Date:_____

< Text End >